PASSWORD CRACKING CON JOHN THE RIPPER

Studente: Vincenzo Lembo
Corso: Cybersecurity & Ethical Hacking
Esercitazione: W14D1
Argomento: Password Cracking
Ambiente: Kali Linux, Metasploitable 2 – UTM

---

1. Obiettivo dell'esercizio

L'obiettivo dell'esercitazione è recuperare le password in chiaro degli utenti presenti nel database dell'applicazione vulnerabile DVWA (Damn Vulnerable Web Application).

L'attività prevede inizialmente l'utilizzo di una vulnerabilità SQL Injection per estrarre dal database i nomi utente e i relativi hash delle password, memorizzati mediante l'algoritmo MD5.

Successivamente, gli hash recuperati vengono sottoposti a un attacco di tipo Dictionary Attack mediante lo strumento John the Ripper, utilizzando il dizionario RockYou.

Lo scopo finale è verificare la possibilità di recuperare le password originali e comprendere i rischi associati all'utilizzo di password deboli e di algoritmi di hashing non adeguati alla protezione delle credenziali.

---

2. Recupero degli hash tramite SQL Injection

Per recuperare gli hash delle password è stata utilizzata l'applicazione DVWA, disponibile sulla macchina Metasploitable 2 all'indirizzo IP `192.168.50.101`.

Dopo aver effettuato l'accesso all'applicazione, è stato impostato il livello di sicurezza su **Low** e selezionata la sezione **SQL Injection**.

Nel campo *User ID* è stata inserita la seguente istruzione:

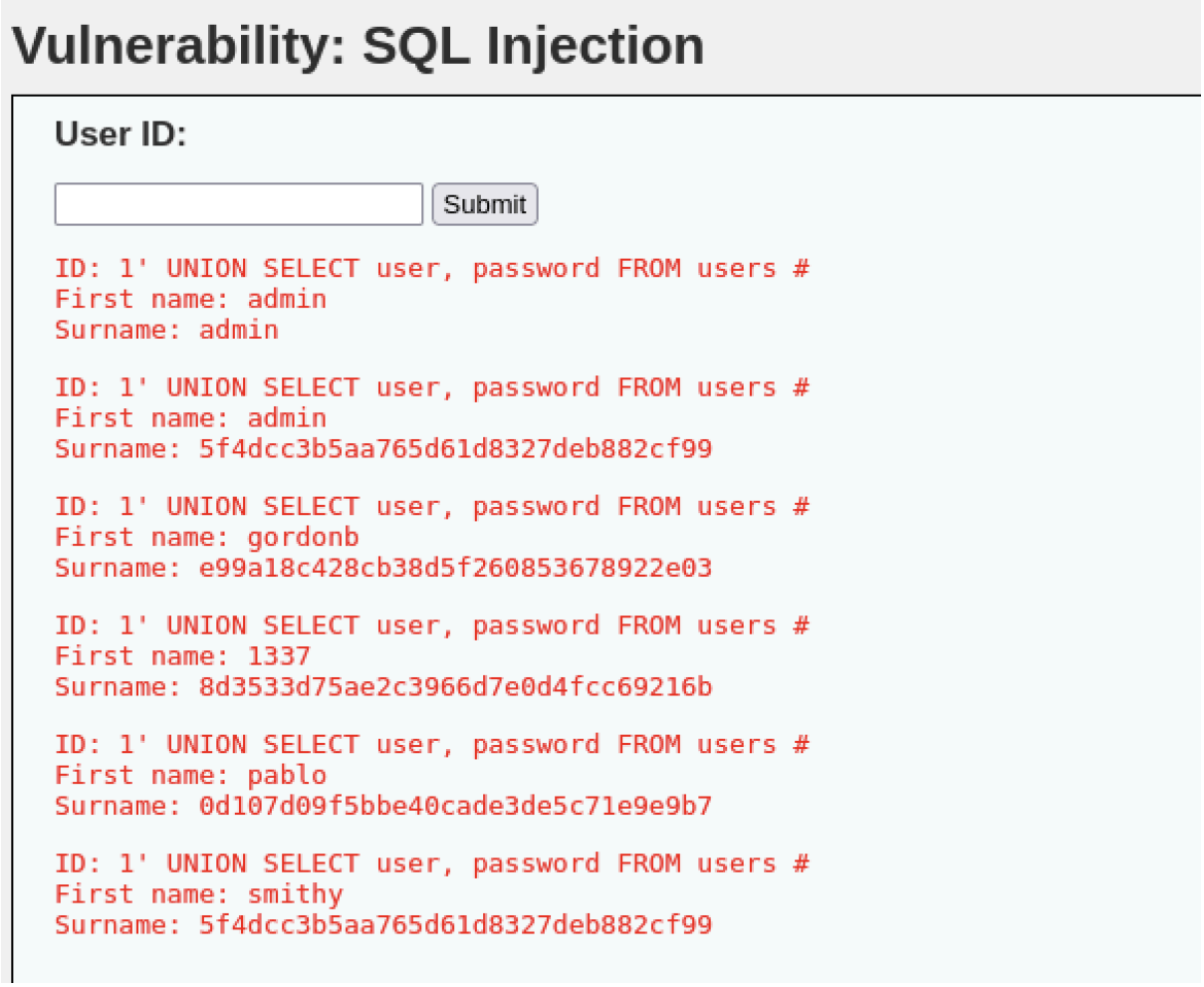
```
1' UNION SELECT user, password FROM users #
```

La tecnica utilizzata è una **UNION-based SQL Injection**, che permette di combinare i risultati della query originale con quelli di una seconda query SQL controllata dall'attaccante.

In particolare:

- `1'` chiude la stringa della query originale.
- `UNION SELECT` permette di aggiungere i risultati di una seconda interrogazione.
- `user, password` indica le colonne da recuperare.
- `FROM users` specifica la tabella contenente le credenziali.
- `#` commenta la parte restante della query originale.

L'esecuzione ha consentito di visualizzare cinque utenti e i relativi hash MD5 delle password.



I risultati ottenuti dimostrano che l'applicazione è vulnerabile a SQL Injection e che un utente malintenzionato potrebbe sfruttare tale vulnerabilità per accedere a informazioni riservate presenti nel database.

---

3. Preparazione degli hash e del dizionario RockYou

Dopo aver recuperato gli hash MD5 attraverso la vulnerabilità SQL Injection, è stato necessario prepararli per l'analisi con John the Ripper.

Tramite il terminale di Kali Linux è stato creato un file denominato `hash.txt`, utilizzando il comando:

```
nano hash.txt
```

All'interno del file sono stati inseriti i cinque hash MD5 precedentemente estratti dal database DVWA, uno per ogni riga.

Successivamente, è stata verificata la presenza del dizionario RockYou nella directory `/usr/share/wordlists/` di Kali Linux.

Il dizionario era disponibile in formato compresso (`rockyou.txt.gz`), pertanto è stato decompresso utilizzando il comando:

```
sudo gzip -dk /usr/share/wordlists/rockyou.txt.gz
```

L'operazione ha permesso di ottenere il file `rockyou.txt`, contenente un elenco di password comunemente utilizzate, da impiegare nell'attacco a dizionario.

Una volta completata la preparazione, sia il file degli hash sia il dizionario erano pronti per essere utilizzati con John the Ripper.

---

4. Esecuzione del cracking con John the Ripper

Per recuperare le password in chiaro è stato utilizzato **John the Ripper**, uno strumento dedicato alla verifica della robustezza delle password attraverso tecniche di password cracking.

La metodologia adottata è stata un **Dictionary Attack (attacco a dizionario)**.

Questa tecnica consiste nel confrontare gli hash delle password da recuperare con quelli generati a partire da un elenco di password candidate contenute in un dizionario.

Nel caso specifico, è stato utilizzato RockYou, un dizionario contenente milioni di password comuni.

Il comando eseguito nel terminale di Kali Linux è stato:

```
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt /home/kali/Desktop/hash.txt
```

Il parametro `--format=raw-md5` specifica l'algoritmo di hashing utilizzato, mentre `--wordlist` indica il dizionario da impiegare durante il cracking.

John the Ripper ha analizzato gli hash presenti nel file `hash.txt`, confrontandoli con quelli calcolati a partire dalle password candidate.

L'operazione si è conclusa con successo, consentendo di recuperare tutte e quattro le password distinte associate ai cinque utenti presenti nel database.



5. Verifica dei risultati ottenuti

Al termine dell'attacco a dizionario è stata effettuata una verifica delle password recuperate, utilizzando il seguente comando:

```
john --show --format=raw-md5 /home/kali/Desktop/hash.txt
```

Il parametro `--show` permette di visualizzare le password precedentemente individuate da John the Ripper, senza eseguire nuovamente il processo di cracking.

L'esecuzione del comando ha restituito il seguente risultato:

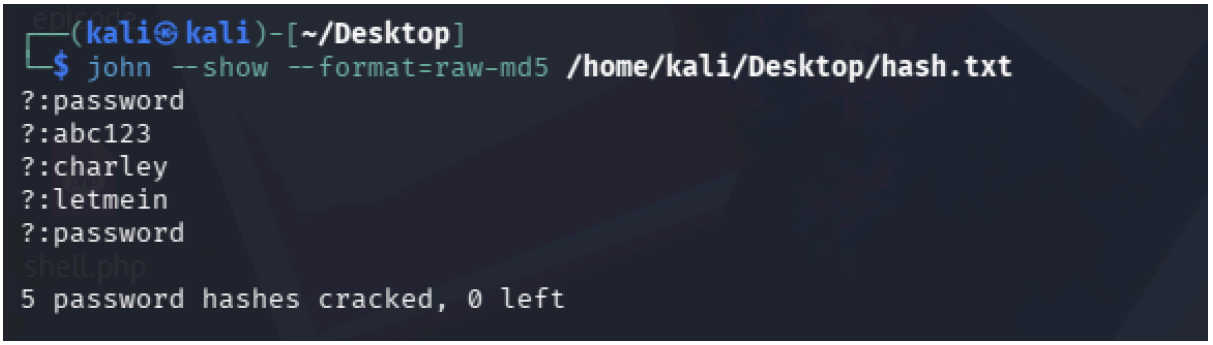
```
5 password hashes cracked, 0 left
```

Questo risultato conferma che tutte le cinque password presenti nel file sono state recuperate correttamente.

Durante l'analisi è stato inoltre osservato che due utenti utilizzavano la stessa password, motivo per cui John the Ripper aveva inizialmente identificato quattro hash distinti.

Le password recuperate sono riportate nella seguente tabella:

Utente	**Password recuperata**
admin	password
gordonb	abc123
1337	charley
pablo	letmein
smithy	password



L'esito dimostra l'efficacia dell'attacco a dizionario nei confronti di password deboli, soprattutto quando queste vengono memorizzate utilizzando algoritmi di hashing rapidi e privi di adeguate protezioni.

---

6. Conclusioni

L'esercitazione ha permesso di comprendere il funzionamento del password cracking e i rischi associati alla gestione non sicura delle credenziali di autenticazione.

Attraverso una vulnerabilità SQL Injection è stato possibile recuperare gli hash MD5 delle password memorizzate nel database DVWA.

Successivamente, mediante John the Ripper e il dizionario RockYou, è stato eseguito un attacco a dizionario che ha consentito di recuperare tutte le password degli utenti analizzati.

Il risultato evidenzia come l'utilizzo di password comuni, combinato con algoritmi di hashing non adeguati alla protezione delle credenziali, possa compromettere la sicurezza degli account.

In conclusione, l'esercizio ha dimostrato come una vulnerabilità SQL Injection possa rappresentare il punto di partenza per la compromissione delle credenziali degli utenti e quanto sia importante adottare misure di sicurezza sia a livello applicativo sia nella gestione delle password.

Vincenzo Lembo